

TOSCANA DIAGNOSTICA S.r.l.

Sistema di Gestione Integrato

PROCEDURA DI ANALISI D'IMPATTO E VALUTAZIONE DEI RISCHI (DPIA)

Valutazione d'impatto sulla protezione dei dati
ai sensi dell'art. 35 GDPR

Codice	Revisione	Data	Pagine
TD-SGI-PRO063_00	00	16/04/2026	3
Redatto da	Approvato da	Classificazione	Stato
RSGI	Direzione Generale	Interno	In vigore

Responsabile del Documento	RSGI	Emissione del Documento
Francesco Epifani	Iacopo Cupelli	Francesco Epifani
16/04/2026	16/04/2026	16/04/2026

Toscana Diagnostica S.r.l.

Via di Pratignone, 13/4, 50019 Sesto Fiorentino (FI). Tel. e Fax: 055776511. Direttore Sanitario: prof. Gian Luigi Taddei.
P.IVA e C.F.: 07528130482, REA n. FI-709602 – Capitale Sociale: € 50.000,00 i.v.

PROCEDURA DI ANALISI D'IMPATTO E VALUTAZIONE DEI RISCHI (DPIA)

Contesto e applicabilità

Questa procedura descrive il processo di Data Protection Impact Assessment (DPIA) per Toscana Diagnostica S.r.l., società di diagnostica sanitaria. La DPIA è richiesta dall'art. 35 del GDPR prima di avviare trattamenti che presentano rischi elevati per i diritti e le libertà dei soggetti interessati.

Soglie di obbligatorietà della DPIA

Una DPIA deve essere condotta quando il trattamento previsto raggiunge una soglia di rischio di almeno 2 dei seguenti criteri:

- Trattamento su larga scala di dati sensibili (sanitari, genetici, biometrici)
- Profilazione sistematica e automatizzata degli interessati
- Monitoraggio sistematico di zone accessibili al pubblico (es. telecamere cliniche)
- Uso di tecnologie nuove o innovative (AI, big data, IoT medicali)
- Trattamento riguardante soggetti vulnerabili (pazienti pediatrici, anziani)
- Trasferimenti transnazionali di dati clinici
- Decisioni automatizzate con effetti legali (es. algoritmi diagnostici)

Esempi di trattamenti soggetti a DPIA presso Toscana Diagnostica

- Gestione referti diagnostici (imaging, analisi di laboratorio)
- Conservazione e trasferimento dati genetici per analisi avanzate
- Raccolta biometrica (impronte, iride) per identificazione pazienti
- Cartelle cliniche elettroniche con accesso remoto di terzi
- Sistemi di imaging diagnostico interconnessi a cloud
- Profilazione paziente per marketing o ricerca clinica

Matrice di Valutazione Rischi

La seguente matrice guida la classificazione del rischio e la decisione sulla DPIA:

Livello di Rischio: BASSO

- Probabilità bassa + Impatto basso → Azione: Accetta rischio, documentare decisione

Livello di Rischio: MEDIO

- Probabilità medio-bassa o Impatto medio → Azione: Mitigare con misure di sicurezza, riesaminare annualmente

Livello di Rischio: ALTO

- Probabilità media o Impatto alto → Azione: Implementare misure di sicurezza robuste, verificare prima dell'avvio

Livello di Rischio: CRITICO

- Probabilità alta + Impatto alto o rischi per diritti fondamentali → Azione: Escalation a DPO e Direzione, bloccare finché non mitigato

Fasi della DPIA (Metodologia 7 Step)

Fase 1: Descrizione e Documentazione

Raccogliere informazioni sul trattamento: natura, scopo, contesto, fonti dati, soggetti interessati, conservazione, flussi informativi, tecnologie impiegate.

Fase 2: Valutazione Necessità e Proporzionalità

Toscana Diagnostica S.r.l.

Via di Pratignone, 13/4, 50019 Sesto Fiorentino (FI). Tel. e Fax: 055776511. Direttore Sanitario: prof. Gian Luigi Taddei.
P.IVA e C.F.: 07528130482, REA n. FI-709602 – Capitale Sociale: € 50.000,00 i.v.

Verificare la liceità del trattamento: scopo determinato, dati adeguati, limitazione conservazione, fondamento legale (consenso, obbligo legale, legittimo interesse).

Fase 3: Consultazione Stakeholder

Coinvolgere il DPO, team Privacy, responsabili di area clinica, fornitori, esperti di sicurezza IT. Condurre incontri e sessioni di lavoro per raccogliere feedback.

Fase 4: Identificazione e Analisi dei Rischi

Analizzare il ciclo di vita dei dati, finalità, tecnologie, soggetti autorizzati. Identificare fonti di rischio: comportamento umano, strumenti informatici, contesto.

Fase 5: Gestione dei Rischi

Decidere se eliminare, mitigare o accettare ciascun rischio. Valutare adeguatezza misure di sicurezza. Predisporre piano di ammodernamento se necessario.

Fase 6: Documentazione e Approvazione

Redigere rapporto DPIA con conclusioni, rischi residui, misure implementate. Sottoporre a DPO per validazione. Se rischi critici, consultare Autorità di Controllo.

Fase 7: Monitoraggio e Revisione

Monitorare implementazione misure. Riesaminare DPIA almeno annualmente o quando cambia il trattamento. Documentare variazioni.